

Technique to gather info about target sys or service by retrieving its "banner" (response/msg of server)

Banner grabbing

GetBanner grabbing is a technique used to gather information about a target system or network by analyzing the banners or responses sent by the system or network services. Here are the detailed steps and tools used for banner grabbing:

1 Pre-Banner Grabbing Steps

1. *Identify the target*: Identify the target system, network, or service you want to gather information about.
2. *Choose a tool*: Choose a tool or technique to perform banner grabbing.
3. *Gather initial information*: Gather initial information about the target, such as its IP address, domain name, or network range.

2 Banner Grabbing Steps

1. *Connect to the target*: Connect to the target system or network using the chosen tool or technique. *eg netcat, telnet, curl etc*
2. *Send a request*: Send a request to the target system or network, such as a TCP SYN packet or an HTTP GET request.
3. *Capture the response*: Capture the response sent by the target system or network, which typically includes a banner or header information.
4. *Analyze the response*: Analyze the response to gather information about the target system or network.

3 Banner Grabbing Tools

1. *Netcat*: A command-line tool used for network exploration and banner grabbing.
2. *Nmap*: A network scanning tool that can be used for banner grabbing.
3. *Telnet*: A protocol used for remote access, which can also be used for banner grabbing.
4. *HTTPIe*: A command-line tool used for HTTP requests and banner grabbing.
5. *curl*: A command-line tool used for transferring data and banner grabbing.
6. *Banner Grabber*: A tool specifically designed for banner grabbing.
7. *Aircrack-ng*: A suite of tools used for wireless network auditing, which includes banner grabbing.

5 Banner Grabbing Techniques

1. *TCP Banner Grabbing*: Using TCP SYN packets to grab banners from TCP-based services.
2. *HTTP Banner Grabbing*: Using HTTP GET requests to grab banners from web servers.
3. *FTP Banner Grabbing*: Using FTP commands to grab banners from FTP servers.
4. *SMTP Banner Grabbing*: Using SMTP commands to grab banners from email servers.

gather info abt the web server by connecting to it retrieving the banner (response) sent by server. gives detail on the SMTP services running on the server

- Countermeasures
1. *Disable unnecessary services*: Disable any unnecessary services or protocols to reduce the attack surface.
 2. *Configure banners*: Configure banners to display minimal information or use custom banners.

HTTP web server

→ `curl -I Siesascs.edu.in`

o/p
Server: Apache
Connection: Alive
Content type: text/html

FTP Server

ftp://ftp.siesascs.edu.in 21

o/p

51w version
connection default port 21 for FTP

(4) SMTP Server

nmmap -p 25 --Script smtp-banner smtp.example.com

FTP :

- ✓ Port 21, 20 → data transfer
↳ control commands
 - ✓ Protocol used connect to File manager & upload & download the file b/w computer & server
- TCP (Transmission control protocol) :

- ✓ Protocol that provides reliable, error-checked delivery of data b/w applications in diff devices on network.
- ✓ no specific port. ports of application.
- ✓ connection-oriented. establishes connection before transmission.
- ✓ TCP along with SSL provides secure comm'.

SMTP (Simple Mail Transfer Protocol)

- ✓ Protocol used to send emails from one server to another or client to server,

~ Port 25, Port 587 (Sending emails securely)

HTTP

- ✓ Protocol for transferring web pages on internet.
- ~ Port 80, port 443 (~~HTTP~~ HTTPS)

3. *Use encryption*: Use encryption to protect communication and prevent banner grabbing.
4. *Implement access controls*: Implement access controls, such as firewalls and access lists, to restrict access to services and protocols.

Remember, banner grabbing is a reconnaissance technique that can be used for both legitimate and malicious purposes. Always use these techniques responsibly and in compliance with applicable laws and regulations.

LIVE SYSTEM SCANNING

Live system scanning is a crucial step in ethical hacking, allowing hackers to gather information about a target system's configuration, vulnerabilities, and potential entry points. Here's a detailed overview of live system scanning, including examples:

Types of Live System Scanning

1. *Network Scanning*: Identifying active hosts, open ports, and services running on a network. *nmmap -sn 192.168.1.0*
2. *Port Scanning*: Detecting open ports and services on a specific host. *ping scan with icmp echo request.*
3. *Service Scanning*: Identifying services running on a host, such as HTTP, FTP, or SSH. *(Just check if the hosts are up)*
4. *OS Detection*: Identifying the operating system (OS) running on a host. *nmmap -P 22,80,443 192.168.1.1*

Live System Scanning Tools

1. *Nmap*: A popular network scanning tool for discovering hosts, services, and OS detection. *nmmap -O 192.168.1.1*
2. *Netcat*: A command-line tool for network exploration and port scanning.
3. *Tcpdump*: A command-line tool for capturing and analyzing network traffic.
4. *Wireshark*: A graphical tool for capturing and analyzing network traffic.

Live System Scanning Techniques

1. *TCP SYN Scanning*: Sending a TCP SYN packet to a host to determine if a port is open.
2. *TCP Connect Scanning*: Establishing a full TCP connection to a host to determine if a port is open.
3. *UDP Scanning*: Sending a UDP packet to a host to determine if a port is open.
4. *ICMP Scanning*: Using ICMP packets to determine if a host is alive.

Examples of Live System Scanning

Nmap Example

```
bash
nmap -sS -O 192.168.1.100
```

This command performs a TCP SYN scan (-sS) and OS detection (-O) on the host with IP address 192.168.1.100.

Netcat Example

...

bash

```
nc -v -z 192.168.1.100 1-1024
```

...

This command performs a TCP connect scan (-z) on the host with IP address 192.168.1.100, scanning ports 1-1024.

Tcpdump Example

...

bash

```
tcpdump -i eth0 -n -vv -s 0 -c 100 -W 100
```

...

This command captures 100 packets (-c 100) on the eth0 interface (-i eth0), displaying packet contents in verbose mode (-vv).

Countermeasures

1. ***Firewalls***: Implementing firewalls to block unnecessary traffic and hide internal networks.
2. ***Access Control Lists (ACLs)***: Configuring ACLs to restrict access to specific hosts and networks.
3. ***Intrusion Detection Systems (IDS)***: Implementing IDS to detect and alert on suspicious network activity.
4. ***Regular Security Audits***: Performing regular security audits to identify vulnerabilities and weaknesses.

By understanding live system scanning techniques and tools, ethical hackers can gather valuable information about a target system, helping to identify vulnerabilities and weaknesses.

Proxy Preparing

In ethical hacking, a proxy server is used to intercept and analyze traffic between a client and a server. This is useful for testing web applications, identifying vulnerabilities, and bypassing security controls. Here's a detailed guide on preparing a proxy server in ethical hacking:

Types of Proxy Servers

1. ***Forward Proxy***: A forward proxy sits between a client and a server, forwarding requests and responses.
2. ***Reverse Proxy***: A reverse proxy sits between a server and multiple clients, forwarding requests and responses.
3. ***Transparent Proxy***: A transparent proxy sits between a client and a server, intercepting and modifying traffic without altering the client's requests.

Preparing a Proxy Server

Step 1: Choose a Proxy Tool

Popular proxy tools for ethical hacking include:

1. ***Burp Suite***: A comprehensive toolkit for web application testing.
2. ***OWASP ZAP***: An open-source web application security scanner.
3. ***Fiddler***: A web debugging proxy for Windows.

Step 2: Set Up the Proxy Server

Configure the proxy tool to listen on a specific port (e.g., 8080) and set up the proxy server to intercept traffic:

1. ***Burp Suite***: Configure the proxy listener in the "Proxy" tab.
2. ***OWASP ZAP***: Configure the proxy settings in the "Tools" menu.
3. ***Fiddler***: Configure the proxy settings in the "Tools" menu.

Step 3: Configure the Client

Configure the client (e.g., web browser) to use the proxy server:

1. ***Browser Settings***: Set the proxy settings in the browser's preferences.
2. ***System Settings***: Set the proxy settings in the operating system's network settings.

Examples

Example 1: Using Burp Suite as a Proxy

1. Launch Burp Suite and configure the proxy listener on port 8080.
2. Configure the client (e.g., Firefox) to use the Burp Suite proxy.
3. Intercept and analyze traffic between the client and server.

Example 2: Using OWASP ZAP as a Proxy

1. Launch OWASP ZAP and configure the proxy settings.
2. Configure the client (e.g., Chrome) to use the OWASP ZAP proxy.
3. Intercept and analyze traffic between the client and server.

Countermeasures

1. ***Use Encryption***: Use SSL/TLS encryption to protect traffic from interception.
2. ***Implement Authentication***: Implement authentication mechanisms to restrict access to sensitive data.
3. ***Use Secure Communication Protocols***: Use secure communication protocols, such as HTTPS, to protect data in transit.

By preparing a proxy server in ethical hacking, you can intercept and analyze traffic, identify vulnerabilities, and test web applications. Remember to use these techniques responsibly and in compliance with applicable laws and regulations.

Vulnerabilities associated with systems

Vulnerabilities are weakness in a system that can be exploited by attackers to gain unauthorized access, disrupt service, or steal sensitive information. Here are some common vulnerabilities associated with systems in ethical hacking, along with examples:

1. Network Vulnerabilities

- *Unsecured Wi-Fi networks*: Weak passwords or unsecured Wi-Fi networks can allow attackers to intercept sensitive information.
- *Open ports*: Unnecessary open ports can provide an entry point for attackers.
- *Misconfigured firewalls*: Firewalls that are not properly configured can allow unauthorized access.

2. Operating System Vulnerabilities

- *Outdated software*: Failing to update operating systems and software can leave systems vulnerable to known exploits.
- *Weak passwords*: Weak passwords can be easily guessed or cracked by attackers.
- *Misconfigured permissions*: Incorrectly configured permissions can allow unauthorized access to sensitive files and directories.

3. Web Application Vulnerabilities

- *SQL injection*: Injecting malicious SQL code can allow attackers to access sensitive data.

- **Cross-site scripting (XSS)**: Injecting malicious code can allow attackers to steal user data or take control of user sessions.
- **Cross-site request forgery (CSRF)**: Tricking users into performing unintended actions can allow attackers to gain unauthorized access.

4. Cryptographic Vulnerabilities

- **Weak encryption**: Using weak encryption algorithms or keys can allow attackers to intercept and decrypt sensitive information.
- **Insufficient key management**: Failing to properly manage encryption keys can compromise the security of encrypted data.

5. Human Vulnerabilities

- **Phishing**: Tricking users into revealing sensitive information can allow attackers to gain unauthorized access.
- **Social engineering**: Manipulating users into performing unintended actions can allow attackers to gain unauthorized access.
- **Insider threats**: Authorized personnel can intentionally or unintentionally compromise the security of a system.

6. Hardware Vulnerabilities

- **Unsecured IoT devices**: Failing to secure IoT devices can allow attackers to gain unauthorized access to networks.
- **Outdated firmware**: Failing to update firmware can leave devices vulnerable to known exploits.
- **Physical access**: Allowing unauthorized physical access to devices can compromise their security.

7. Configuration Vulnerabilities

- **Misconfigured servers**: Incorrectly configured servers can provide an entry point for attackers.
- **Misconfigured databases**: Incorrectly configured databases can allow unauthorized access to sensitive data.
- **Misconfigured firewalls**: Firewalls that are not properly configured can allow unauthorized access.

8. Patch Management Vulnerabilities

- **Unpatched vulnerabilities**: Failing to patch known vulnerabilities can leave systems open to exploitation.
- **Delayed patching**: Delaying patching can allow attackers to exploit known vulnerabilities.

9. Authentication Vulnerabilities

- **Weak authentication**: Using weak authentication mechanisms can allow attackers to gain unauthorized access.

- *Insufficient session management*: Failing to properly manage user sessions can allow attackers to hijack user sessions.

10. Logging and Monitoring Vulnerabilities ✓

- *Insufficient logging*: Failing to properly log system activity can make it difficult to detect and respond to security incidents.

[01/02, 2:53 pm] Meta AI: Vulnerabilities are weaknesses in a system that can be exploited by attackers to gain unauthorized access, disrupt service, or steal sensitive information. Here are some common vulnerabilities associated with systems in ethical hacking, along with examples:

1. Network Vulnerabilities

- *Unsecured Wi-Fi networks*: Weak passwords or unsecured Wi-Fi networks can allow attackers to intercept sensitive information.
- *Open ports*: Unnecessary open ports can provide an entry point for attackers.
- *Misconfigured firewalls*: Firewalls that are not properly configured can allow unauthorized access.

2. Operating System Vulnerabilities

- *Outdated software*: Failing to update operating systems and software can leave systems vulnerable to known exploits.
- *Weak passwords*: Weak passwords can be easily guessed or cracked by attackers.
- *Misconfigured permissions*: Incorrectly configured permissions can allow unauthorized access to sensitive files and directories.

3. Web Application Vulnerabilities

- *SQL injection*: Injecting malicious SQL code can allow attackers to access sensitive data.
- *Cross-site scripting (XSS)*: Injecting malicious code can allow attackers to steal user data or take control of user sessions.
- *Cross-site request forgery (CSRF)*: Tricking users into performing unintended actions can allow attackers to gain unauthorized access.

4. Cryptographic Vulnerabilities

- *Weak encryption*: Using weak encryption algorithms or keys can allow attackers to intercept and decrypt sensitive information.
- *Insufficient key management*: Failing to properly manage encryption keys can compromise the security of encrypted data.

5. Human Vulnerabilities

- *Phishing*: Tricking users into revealing sensitive information can allow attackers to gain unauthorized access.
- *Social engineering*: Manipulating users into performing unintended actions can allow attackers to gain unauthorized access.

- **Insider threats**: Authorized personnel can intentionally or unintentionally compromise the security of a system.

6. Hardware Vulnerabilities

- **Unsecured IoT devices**: Failing to secure IoT devices can allow attackers to gain unauthorized access to networks.
- **Outdated firmware**: Failing to update firmware can leave devices vulnerable to known exploits.
- **Physical access**: Allowing unauthorized physical access to devices can compromise their security.

7. Configuration Vulnerabilities

- **Misconfigured servers**: Incorrectly configured servers can provide an entry point for attackers.
- **Misconfigured databases**: Incorrectly configured databases can allow unauthorized access to sensitive data.
- **Misconfigured firewalls**: Firewalls that are not properly configured can allow unauthorized access.

8. Patch Management Vulnerabilities

- **Unpatched vulnerabilities**: Failing to patch known vulnerabilities can leave systems open to exploitation.
- **Delayed patching**: Delaying patching can allow attackers to exploit known vulnerabilities.

9. Authentication Vulnerabilities

- **Weak authentication**: Using weak authentication mechanisms can allow attackers to gain unauthorized access.
- **Insufficient session management**: Failing to properly manage user sessions can allow attackers to hijack user sessions.

10. Logging and Monitoring Vulnerabilities

- **Insufficient logging**: Failing to properly log system activity can make it difficult to detect and respond to security incidents.
- **Insufficient monitoring**: Failing to properly monitor system activity can make it difficult to detect and respond to security incidents.

These are just a few examples of vulnerabilities associated with systems in ethical hacking. It's essential to stay up-to-date with the latest vulnerabilities and patches to ensure the security of systems

Vulnerability assessment